

Alumna: Nahomy Dafne Cante Jiménez
Lunes 31 de agosto del 2026
Análisis y planificación del pentest

Caso: Aurora Market

Empresa mexicana de comercio electrónico en una aplicación web.

Objetivo

El propósito de esta evaluación es identificar la presencia de vulnerabilidades de control de acceso (IDOR), poniendo a prueba las rutas web, la interfaz y los parámetros numéricos de navegación para comprobar si es posible vulnerar los límites entre cuentas. Con este ejercicio se busca verificar que el *backend* valide rigurosamente la autorización en cada consulta, asegurando que el usuario posea permisos legítimos sobre el recurso antes de devolver cualquier información a la pantalla.

Además, la evaluación localiza los datos de perfil expuestos —incluyendo información personal, historiales de compra y métodos de pago— para dimensionar con exactitud el nivel de criticidad si un atacante logra explotar estos fallos. El valor para su organización radica en obtener una perspectiva clara del riesgo real, permitiendo blindar la lógica de autorización y proteger los activos más sensibles de sus usuarios frente a accesos no autorizados.

Alcance

Sí se evaluará

- Aplicación web.

NO se evaluará

- Redes sociales de la empresa.
- Dispositivos del personal interno.
- Cuentas de correo electrónico asociadas.
- Proveedores externos.
- Sistemas vinculados.

Permisos y condiciones

Permisos requeridos

- Autorización formal para realizar la prueba de pentest en la aplicación web.

ACTIVIDAD 01 - ETHICAL HACKING - HACKER WOMEN 2026

- Conocimiento de la información parcial proporcionada sobre la infraestructura (se reconoce por parte de su equipo la existencia de los mecanismos de autenticación, los tipos de usuarios y una base de datos).

Condiciones acordadas

- No interrumpir deliberadamente el funcionamiento de la plataforma.
- No afectar la información real de los clientes.
- Realizar las pruebas durante horarios de menor actividad para reducir cualquier posible impacto sobre sus operaciones.
- Entregar documento detallado para revisión del equipo de desarrollo que incluya la identificación de los riesgos existentes, el análisis de sus posibles afectaciones y la sugerencia de medidas que deben tomarse para la reducción de los mismos.

Metodología

Tipo de Pentest

Gray-box

Este enfoque permitiría simular la lógica del negocio mediante el acceso con credenciales, con la intención de manipular los permisos y las peticiones de la plataforma para escalar privilegios hasta ver datos ajenos del usuario. Esta gestión de las sesiones lograría verificar cuándo el sistema aísla correctamente la información entre los diferentes tipos de usuarios.

Además, una de las condiciones previamente señaladas es que no se entregará toda la información técnica de la infraestructura, a sabiendas de que se desconocen todos los detalles sobre cómo está construida la plataforma y la tecnología que utiliza, por lo que la opción del tipo *white-box* que se adentra a conocer el sistema no es viable. Y la del tipo *black-box* impediría cumplir con los objetivos establecidos.

Modelo

Open Web Application Security Project (OWASP)

En razón de que este modelo funciona como la guía de referencia mundial para la seguridad en aplicaciones web y de *APIs*, lo que lo vuelve adecuado para el comercio electrónico. Entre sus entradas se encuentra el caso específico de IDOR, dentro de la categoría de **Broken Access Control**, relacionada con los controles de autenticación, la gestión de sesiones y las pruebas de control de acceso.

Recopilación de información previa

Métodos y fuentes de recopilación

1. Fuentes abiertas (basadas en el **framework OSINT**): búsqueda de subdominios, metadatos y posibles fugas de credenciales en internet para mapear la exposición inicial de la plataforma de comercio electrónico.

ACTIVIDAD 01 - ETHICAL HACKING - HACKER WOMEN 2026

2. Fuentes internas y operativas: reconocimiento directo e interacción controlada con el portal de usuarios y la interfaz de administración para descubrir endpoints, rutas y parámetros ocultos.

Herramientas con propósito operativo

1. **OWAS ZP**. Es la herramienta central para investigar el reporte del usuario, ya que permite manipular de forma controlada los parámetros numéricos de navegación y las peticiones para detectar fallos de control de acceso (IDOR) y comprobar si un cliente puede visualizar información de otros perfiles.
2. **Nmap**. Permitiría verificar si existen servicios auxiliares expuestos innecesariamente a internet (como puertos de bases de datos o paneles de gestión mal configurados) que amplíen la superficie de ataque del sistema de comercio electrónico.
3. **Gobuster** (*opcional*). Ayudaría directamente a verificar si la interfaz de control reservada para el personal de administración cuenta con accesos directos ocultos o mal protegidos que un atacante podría descubrir sin autenticarse.
4. **Wappalyzer** (*opcional*). Para determinar si la plataforma de comercio electrónico utiliza componentes con vulnerabilidades públicas conocidas, permitiendo enfocar las pruebas hacia los puntos débiles específicos de la arquitectura actual.

Recursos necesarios

- Credenciales de acceso / cuentas de usuario de prueba (mínimo 2 para alternar los accesos y contrastar el cruce de información entre ellos).
- Navegador web para rutear el tráfico con proxy de intercepción para encontrar vulnerabilidades a partir de las peticiones *HTTP* y *HTTPS* que se envían al servidor (tal como *OWASP ZAP*).
- Acuerdo operativo que defina explícitamente los objetivos de ejecución, sus fechas y horarios, además de los canales de notificación y emergencia con el equipo designado de la empresa.
- Herramienta de documentación y control de versiones (*GitHub*).

Programación del Pentest

1. Reconocimiento de infraestructura (lunes y martes (01:00 AM – 05:00 AM))

Se utiliza **OWASP ZAP** para registrar el tráfico de las cuentas de prueba (usuario y administrador) y mapear todas las rutas, formularios y parámetros numéricos, complementado con un escaneo de puertos mediante **Nmap** y **Gobuster** para identificar servicios y componentes expuestos en la infraestructura.

Iniciar con las pruebas en estas condiciones de tiempo minimizaría el tráfico operativo en la plataforma de comercio electrónico y evitaría saturar los recursos del servidor durante la consulta de catálogos y la asignación de cuentas de prueba.

2. Análisis de vulnerabilidades (miércoles y jueves (02:00 AM – 06:00 AM))

Se examina el comportamiento del sistema bajo los lineamientos del **Top 10 de OWASP**, analizando las respuestas del servidor para detectar con **Wappalyzer** si el *backend* carece de validaciones de permisos en las peticiones y estableciendo las líneas base de control de acceso.

Las pruebas automatizadas y la enumeración de directorios pueden generar latencia; ejecutarlas en la madrugada previene afectaciones al rendimiento de los usuarios activos.

3. Explotación controlada (viernes (01:00 AM – 05:00 AM))

Se ejecutan pruebas activas alterando identificadores numéricos en las peticiones web e intercambiando *tokens* de sesión entre perfiles para comprobar si es posible saltar los límites de seguridad y visualizar información ajena sin autorización.

Al ser esta la etapa decisiva, se destaca que la manipulación de parámetros y la alteración de peticiones *HTTP* en el *backend* requieren un entorno estable para evitar bloqueos masivos de sesiones o falsas alertas en los sistemas de monitoreo diurno, por lo que será una etapa intensiva.

4. Post-explotación (sábado (horario flexible / coordinado))

Se evalúa el alcance real de la brecha determinando qué volumen de datos sensibles —como perfiles, historiales de compra y métodos de pago— quedaría expuesto de forma masiva ante un atacante.

El fin de semana facilita la validación de la exposición de datos sensibles y la recopilación de evidencias sin interferir con las operaciones comerciales del fin de semana.

5. Informe (miércoles próximo entrega a primera hora del día)

Se documentan técnicamente los hallazgos con evidencias de concepto, métricas de riesgo y recomendaciones de remediación orientadas al código, culminando con una presentación ejecutiva para la toma de decisiones del cliente.

Precisando el uso de **OWASP ZAP** como proxy de interceptación para capturar, modificar y analizar las peticiones *HTTP* enviadas entre el navegador y el servidor durante el mapeo de URLs y botones; apoyándose en el propio **Modelo de OWASP**, con el propósito es enfocar la revisión hacia los riesgos web más críticos identificados en el escenario: el control de acceso roto (IDOR), la manipulación de parámetros y la falta de validación de permisos en el *backend*, respondiendo directamente al reporte previo de un usuario que aseguró visualizar información ajena.

Contraste y complementación del documento de **Análisis de Riesgo Preventivo** que se agrega a continuación.

Anexo

Análisis de Riesgo Preventivo

- **Control de Acceso Roto (IDOR):**
 - *Riesgo:* que la manipulación de parámetros numéricos en las peticiones web permita acceder a los recursos de otros usuarios.
 - *Afectación:* robo masivo de cuentas y usurpación de identidad mediante la exposición de perfiles ajenos.
 - *Medidas:* validar la propiedad de los datos en el servidor antes de responder y utilizar identificadores aleatorios en lugar de secuencias numéricas predecibles.
- **Exposición de información sensible:**
 - *Riesgo:* que el sistema entregue a la pantalla datos privados de perfiles, historiales de compra y métodos de pago sin la debida protección.
 - *Afectación:* pérdida de confianza de los clientes, multas por incumplimiento normativo y riesgos de fraude financiero.
 - *Medidas:* programar el servidor para enviar únicamente los datos indispensables y aplicar enmascaramiento a la información financiera o delicada.
- **Falta de verificación en el *backend*:**
 - *Riesgo:* que la seguridad dependa únicamente de ocultar elementos en la interfaz visual, permitiendo peticiones directas al servidor.
 - *Afectación:* acceso no autorizado a funciones administrativas y áreas restringidas del sistema.
 - *Medidas:* implementar una regla de "denegar por defecto" en el servidor y centralizar la validación de permisos legítimos para cada consulta realizada.